

ACTIVITY PACK

Activity 1 - Threat Modelling a Generative AI Concierge

Complete learner scenario, practice and security checklist

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	3.0 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Readme

Activity 1 - Threat Modelling a Generative AI Concierge

Course: AI Security for Autonomous AI Agents **Course Code:** TGS-2025060473 | **TSC:** ICT-INT-0052-1.1 **Block:** Day 1
- Generative AI Security

At a glance

Duration	45 minutes
Format	Small groups of 3 - 4, plenary debrief
Type	Realistic synthetic simulation (SIM)
Learning Outcome	LO1
K/A statements assessed	K2, K3, A4

Purpose

Learners threat-model a fictional deployed hospitality GenAI concierge, identify trust boundaries and attacker-writable retrieval sources, turn each application mode into an attack surface, and make a rollout recommendation with costed controls.

Files in this folder

File	Audience	Use
SCENARIO.md	Learner	The case study narrative, artefacts and data
DISCUSSION-QUESTIONS.md	Learner	The five questions to work through in groups
SECURITY-CHECKLIST.md	Learner	Deployment evidence checklist for the concierge
Activity-1-*.pdf	Learner	Printable full learner pack including the checklist

How to run it

1. **Set up (5 min).** Form groups of 3 - 4. Issue SCENARIO.md and DISCUSSION-QUESTIONS.md. Trainer debrief notes are supplied separately and are not stored in the learner-facing Activities folder.
2. **Group work (30 minutes).** Groups work the five questions in order. Circulate; the questions are designed to be argued, not looked up.
3. **Presentation (5 minutes).** Each group presents its answer to one nominated question.
4. **Debrief (5 minutes).** Use the separate trainer notes to draw out the teaching points and correct recurring misconceptions.

Learner workflow

1. Inventory every channel, retrieval source, data store, model, tool and output consumer in the scenario.
2. Draw the data flow and mark each boundary where a public, partner or internal writer can place content into model context.
3. Mark personal data, secrets and business-sensitive data, including purpose, owner and retention.
4. Write one realistic abuse case for every attacker-writable source; do not test a live system.
5. Trace each abuse case from source through model interpretation, identity and tool authority to its possible effect.
6. Rank the boundaries by impact, likelihood, reversibility and detection difficulty.
7. Select the earliest deterministic control for the top three risks and record owner, test evidence, residual risk and operational cost.

8. Decide proceed, conditional proceed or halt, then complete SECURITY-CHECKLIST .md.

Required evidence

- One labelled data-flow diagram covering at least three channels, four retrieval sources and four tools.
- One ranked abuse-case table with a source-to-sink chain for every shortlisted risk.
- Three control decisions, each with an owner, evidence test, residual risk and operational cost.
- One rollout decision supported by the completed deployment checklist.

Acceptance criteria

The submission passes when every external writer, personal-data path and action tool is represented; the three priority risks can be traced end to end; and the rollout decision is supported by testable, owned controls rather than prompt wording alone.

The slide deck remains concept-led. These learner procedures are also reproduced in the Learner Guide.

Alignment

Every question in DISCUSSION-QUESTIONS .md is tagged with the K or A statement it evidences. This activity contributes to **LO1** and is assessed through the Written Assessment (SAQ) and the Case Study.

This material belongs to Tertiary Infotech Pte Ltd (UEN: 20120096W). All Rights Reserved.

Scenario

Activity 1 - Scenario

Threat Modelling a Generative AI Concierge

Course: AI Security for Autonomous AI Agents (TGS-2025060473) **Duration:** 45 minutes | **Format:** Small groups of 3 - 4 | **Type:** Realistic synthetic simulation

Evidence status: SIM. The organisation, people, events, record counts, performance figures, and financial values in this scenario are fictional and exist only for classroom analysis.

The simulated organisation

Marina Crescent Hotel is a 340-room business hotel on Singapore's waterfront, part of a regional group with properties in Kuala Lumpur, Bangkok and Jakarta. Occupancy runs at 82%, and roughly 60% of guests are corporate travellers on negotiated rates.

The hotel's guest satisfaction scores have slipped for three consecutive quarters. Exit surveys point at one cause: the front desk is overwhelmed between 3pm and 7pm, and guests wait an average of eleven minutes for simple requests.

The deployment

Six weeks ago, the group's digital team launched "**Cres**" - a generative AI concierge - without consulting the group security function. Cres is live on three channels:

- the in-room tablet,
- WhatsApp (guests message a published number), and
- the public website chat widget (no login required).

Cres is built on a commercial large language model with a retrieval layer. To answer guest questions it retrieves from four sources:

Source	Contents	Who can write to it
Property knowledge base	Facilities, opening hours, policies	Marketing team
Guest profile service	Name, loyalty tier, stay history, dietary notes, passport number (from check-in)	Property management system
Local events feed	Third-party API of Singapore events and attractions	External vendor
Guest review corpus	Scraped public reviews from travel sites, refreshed nightly	Automated scraper

Cres can also perform four actions through tool calls: **book a restaurant table**, **raise a housekeeping ticket**, **order room service to a room number**, and **email a folio (bill) copy to a guest's registered address**.

What the digital team believes

The project lead has told the executive committee:

"Cres is safe. It only sees hotel data, it has a system prompt that tells it never to reveal personal information, and we tested it with over two hundred guest questions before launch. It has no access to payment card data, so PDPA is not really in scope for us."

Early signals

Three things have happened that nobody has yet connected:

1. A guest posted a screenshot on social media showing Cres greeting them with ****another guest's name and loyalty tier****. The digital team closed the ticket as "a caching glitch."
2. The events vendor was acquired last month. Their API now returns a longer description field for each event; nobody reviewed the change.

3. Room service received an order for a room that was **unoccupied**, charged to a guest who had already checked out. Finance wrote it off as a \$46 error.

Your role

You are the newly appointed **AI security working group**. The executive committee has asked you to produce a threat model for Cres before the group rolls it out to the other three properties next quarter. The committee is not technical; they respond to risk, cost and reputation.

You have this scenario, and nothing else. Work from what the architecture tells you.

Discussion Questions

Activity 1 - Discussion Questions

Threat Modelling a Generative AI Concierge

Work through all five questions in your group. Nominate one person to present your threat model in the debrief. You have 45 minutes.

Q1 - Map the trust boundaries (K2)

Draw the data flow for Cres: the three channels in, the four retrieval sources, and the four tool actions out.

- Mark every point where **untrusted content** enters the model's context window.
- For each, state **who controls that content** and whether the hotel can verify it.
- The model cannot reliably tell the difference between the hotel's instructions and text that

merely *appears* in its context. Explain, in language the executive committee would follow, **why this is a property of how generative models work** rather than a bug the vendor can patch.

Q2 - Rank the retrieval sources by risk (K2, K3)

Of the four retrieval sources, two are **attacker-writable** in practice.

- Identify which two, and explain the path by which an outsider gets text into them.
- The project lead proposes adding "a classifier that detects malicious instructions before they

reach the model." That classifier is a **discriminative** model policing a **generative** one. Explain what that classifier can and cannot do, and why it is a control worth having but not a control worth trusting on its own.

Q3 - Turn each capability into an attack surface (A4)

Cres performs four application functions: **summarisation** (reviews, event listings), **inference** (guest preferences), **transformation** (formatting a folio), and **augmentation** (enriching answers from retrieval).

For **each** of the four, describe one concrete way an attacker abuses that specific function. Be precise about the attacker's goal - data, money, disruption or reputation.

Q4 - Explain the three early signals (K2, A4)

The three incidents in the scenario are not unrelated glitches.

- Give the most likely technical cause of each.
- Which events require a formal PDPA breach assessment? Apply the current significant-harm and significant-scale tests without assuming that every data leak is automatically notifiable.
- The project lead says PDPA is not in scope because Cres holds no payment card data. Rebut this.

Q5 - Recommend the deployment decision (A4)

The committee wants a one-slide answer for the rollout to three more properties.

- Recommend **proceed**, **proceed with conditions**, or **halt**, and justify it.
- List the **three** controls you would require before any further rollout, in priority order.
- For each control, name what it costs the business - latency, money, guest friction or staff effort. A recommendation that pretends controls are free will not survive the committee.

Security Checklist

Activity 1 - GenAI Concierge Security Checklist

Use this checklist to turn the threat model into a deployment decision. Mark each item Yes, No, or Not evidenced, and cite the scenario artefact that supports your answer.

Purpose and ownership

- ☐ The concierge has a named business owner, technical owner, security reviewer and DPO contact.
- ☐ Permitted guest tasks, prohibited tasks and supported channels are documented.
- ☐ Expansion to other properties requires a fresh risk and cross-border data review.

Content and data

- ☐ Every input source is classified by owner, trust level, update method and data sensitivity.
- ☐ Guest profiles, prompts, retrieved content, outputs, tool arguments and logs appear in the personal-data inventory.
- ☐ Retrieval is scoped to the current authenticated guest and stay; public users cannot reach guest data.
- ☐ Retention and deletion periods exist for conversations, memory, screenshots and logs.

Tools and actions

- ☐ The agent has a distinct identity and separate read/write permissions for each tool.
- ☐ Tool parameters bind room, guest and reservation identifiers before execution.
- ☐ Folio email goes only to a verified registered address; recipient override is impossible.
- ☐ Charges, refunds, profile changes and cross-guest disclosures require deterministic human approval.
- ☐ Rate, cost, retry and sequence limits prevent runaway actions.

Detection and response

- ☐ Logs distinguish user input, retrieved content, model proposal, approval and executed action.
- ☐ Alerts cover cross-guest retrieval, unoccupied-room orders, recipient changes and unusual tool sequences.
- ☐ A kill switch, credential-revocation path, owner and response time are tested.
- ☐ The DPO can assess significant harm and scale using preserved evidence.

Decision

- ☐ Proceed.
- ☐ Proceed only after the stated controls are evidenced.
- ☐ Halt because the use case cannot be bounded within risk tolerance.

Record the three highest-priority gaps, the owner for each remediation and the due date.